

AI Governance & Acceptable Use Policy

NovaTech Solutions (Fictional Organization)

Prepared by Dhriti Pandya

1. Purpose

The purpose of this policy is to establish requirements for the responsible and secure use of artificial intelligence at NovaTech Solutions. It is intended to protect sensitive and proprietary information, reduce security and privacy risks, support applicable legal and organizational requirements, and create consistent expectations for AI use across departments.

2. Scope

This policy applies to NovaTech employees, contractors, and interns who use artificial intelligence for company-related activities. It covers generative AI tools and services, whether internally provided or externally hosted, and applies to AI use on company-managed devices as well as personal devices used to access, process, or handle NovaTech information.

The policy includes AI activities involving company information, proprietary source code, employee or customer data, and operational or business decision-making.

3. Roles & Responsibilities

- **Information Security:** Reviews and approves AI tools from a security perspective and defines or supports required security controls.
- **Privacy/Legal:** Reviews applicable AI use cases for privacy, legal, regulatory, and contractual requirements and determines whether additional authorization is required.
- **Employees and AI Users:** Use approved tools, protect organizational information, follow data and use-case restrictions, verify AI output when required, and report suspected incidents or policy violations.
- **Business/Process Owners:** Ensure AI use within their area follows this policy and that required human review is performed.

4. Acceptable AI Use

Approved AI tools may be used for authorized business purposes when required security, privacy, and human-review requirements are followed. Examples include:

- HR using an approved AI tool to summarize de-identified employee engagement feedback.
- Finance using AI for a first-pass internal report summary when an authorized reviewer verifies the output against authoritative source data.
- Software Development using an approved AI coding assistant for boilerplate, documentation, tests, or code suggestions that still go through required review and security checks.
- Marketing or Customer Support using approved AI tools to draft content that is reviewed before external or official use.

5. Prohibited AI Use

- Uploading confidential, sensitive, restricted, or otherwise protected NovaTech information to an unapproved AI tool.
- Submitting proprietary source code, algorithms, or designs to an external AI service unless the tool and specific use are explicitly authorized.
- Merging or deploying AI-generated code without required qualified developer review and security/quality testing.
- Using AI-generated financial or operational content as an authoritative source without required verification.
- Using AI to independently make high-impact decisions, such as employee disciplinary or performance decisions, or to produce regulated reporting without required authorization, human oversight, and applicable review.
- Using unapproved AI tools for company work outside the established AI tool intake and approval process.

6. Data Handling Requirements

- AI tools used for company work must be reviewed and approved by Information Security and, where applicable, Privacy/Legal.
- Sensitive, confidential, restricted, or identifiable data must not be submitted to an AI system unless the specific system, data type, and use case are authorized.
- Data should be de-identified, masked, or sanitized when appropriate before approved AI use.
- Proprietary source code, algorithms, and designs must not be submitted to external AI services unless the tool and use are explicitly authorized.
- Approval of an AI tool does not automatically approve every data type or every business use case.

7. Human Oversight & Validation

- Business-critical financial, operational, or decision-support content produced with AI must be reviewed and verified by a qualified employee before official use or decision-making.
- AI-generated code must be reviewed and approved by a qualified developer and pass required security and quality checks before merge or production deployment.
- Human review must be meaningful; an approval click without appropriate validation does not satisfy the intent of this policy.

8. AI Tool Approval & Shadow AI

Employees must submit new AI tools through NovaTech's established intake and approval process before using them for company work. Information Security will review security considerations and will involve Privacy/Legal when the proposed use raises privacy, legal, regulatory, or contractual concerns. NovaTech may use technical controls and monitoring to restrict or identify known unapproved AI services.

The level of review should be based on the risk of the tool and use case rather than assuming every AI tool requires exactly the same review.

9. Reporting & Response

Personnel must promptly report suspected or confirmed AI-related security incidents, data exposures, unauthorized AI use, or policy violations to Information Security through established reporting channels.

NovaTech will investigate and address reported events under applicable security incident, privacy, HR, and organizational procedures.

10. Policy Review

This policy should receive a formal review at least once every 12 months. Earlier review should occur after a significant AI-related incident, a material legal or regulatory change, or the introduction of a new high-risk AI technology or use case.

Portfolio Note

This is a proposed policy created for a fictional organization as part of an educational cybersecurity GRC portfolio project. It has not been formally adopted by a real organization.